

Relatório de Consultoria em Segurança da Informação

BrightTech Soluções Digitais Ltda.

Relatório de Consultoria em Segurança da Informação BrightTech Soluções Digitais Ltda.

1. **Resumo Executivo** Este relatório apresenta o resultado de uma consultoria especializada conduzida pela equipe de segurança da informação, com o objetivo de desenvolver um conjunto estruturado de políticas de segurança aplicáveis à BrightTech Soluções Digitais Ltda. O foco principal é a criação de um ambiente seguro, resiliente e alinhado às melhores práticas de governança de TI, conforme as diretrizes da ISO/IEC 27001 e boas práticas do NIST (National Institute of Standards and Technology). O documento consolida diretrizes voltadas à gestão de acessos, segurança de dispositivos e redes, resposta a incidentes e estratégias de backup e recuperação, considerando a realidade operacional de uma pequena empresa do setor de tecnologia.

2. **Escopo do Trabalho** O escopo deste trabalho contempla a análise e o desenvolvimento de políticas básicas de segurança da informação aplicáveis a uma estrutura corporativa enxuta, composta por cerca de 20 colaboradores. As áreas avaliadas incluem: - Gestão de identidade e controle de acesso; - Segurança de endpoints e rede corporativa; - Processos de resposta a incidentes de segurança cibernética; - Continuidade de negócios e recuperação de desastres. As recomendações aqui descritas têm caráter consultivo e visam estabelecer um nível mínimo de conformidade e maturidade em segurança da informação.

3. **Análise da Situação Atual** A BrightTech Soluções Digitais Ltda. é uma empresa em crescimento que depende fortemente de sistemas digitais para o desenvolvimento e entrega de seus serviços. Observou-se, no entanto, a ausência de políticas formais que padronizem o uso dos recursos tecnológicos, o que representa um risco potencial à confidencialidade, integridade e disponibilidade das informações. Durante a análise, foram identificadas práticas informais de controle de acesso, ausência de mecanismos de auditoria e inexistência de um processo estruturado de backup e resposta a incidentes. Diante disso, propõe-se a implementação das políticas descritas a seguir.

4. Políticas de Segurança da Informação

4.1. **Política de Acesso e Controle de Usuários** **Objetivo:** Estabelecer diretrizes para autenticação, autorização e auditoria de usuários, garantindo que apenas indivíduos devidamente autorizados acessem os sistemas corporativos. **Diretrizes:** - Implementar controle de identidade baseado em usuários individuais, com autenticação por senha complexa (mínimo de 10 caracteres, contendo letras maiúsculas, minúsculas, números e símbolos). - Adotar o princípio do menor privilégio (least privilege), concedendo acesso apenas conforme as responsabilidades funcionais. - Implantar políticas de expiração e bloqueio de contas inativas após 30 dias sem uso. - Utilizar autenticação multifator (MFA) em sistemas críticos, como servidores de dados e plataformas de gestão. - Monitorar e registrar logs de acesso para fins de auditoria e rastreabilidade. **Justificativa:** O controle rigoroso de identidade e autenticação reduz

riscos de acesso não autorizado e contribui para o cumprimento de normas de conformidade digital.

4.2. Política de Uso de Dispositivos Móveis e Redes Objetivo: Garantir o uso seguro de dispositivos móveis, estações de trabalho e redes corporativas, prevenindo vazamentos e comprometimentos de dados. Diretrizes: - Exigir que todos os dispositivos conectados à rede corporativa estejam atualizados e com antivírus ativo. - Restringir o uso de dispositivos pessoais (BYOD) apenas a colaboradores autorizados, mediante instalação de políticas de segurança corporativas (MDM – Mobile Device Management). - Configurar rede Wi-Fi corporativa com criptografia WPA3 e senhas trocadas periodicamente. - Exigir o uso de VPN (Virtual Private Network) para acessos remotos a servidores e sistemas internos. - Proibir a utilização de mídias removíveis sem prévia varredura de segurança. Justificativa: Essas práticas fortalecem a segurança do perímetro digital da empresa, mitigando ameaças como ataques de malware, interceptação de dados e engenharia social.

4.3. Diretrizes para Resposta a Incidentes de Segurança Objetivo: Estruturar um plano de resposta a incidentes (Incident Response Plan – IRP) que permita rápida detecção, contenção e recuperação de falhas de segurança. Diretrizes: - Estabelecer um canal formal de comunicação para notificação de incidentes (ex.: e-mail dedicado ou sistema de chamados). - Criar uma equipe responsável pela análise e tratamento de incidentes, com papéis definidos (responsável técnico, gestor e comunicador). - Documentar cada incidente com informações sobre origem, impacto, medidas corretivas e lições aprendidas. - Adotar métricas de tempo de resposta (MTTR) e tempo de detecção (MTTD) para mensurar a eficiência do processo. - Promover treinamentos periódicos de conscientização em segurança da informação. Justificativa: Um processo estruturado de resposta reduz significativamente o impacto financeiro e operacional de incidentes, permitindo rápida recuperação das operações.

4.4. Política de Backup e Recuperação de Desastres Objetivo: Garantir a continuidade dos serviços e a disponibilidade das informações em caso de falhas, ataques ou desastres físicos. Diretrizes: - Implementar rotinas automáticas de backup diário, armazenando cópias em nuvem e em local físico distinto. - Utilizar criptografia AES-256 para proteção dos arquivos de backup. - Testar periodicamente os procedimentos de restauração (no mínimo uma vez por mês). - Classificar os sistemas críticos e estabelecer prioridades de recuperação (Recovery Time Objective – RTO e Recovery Point Objective – RPO). - Elaborar e manter atualizado o Plano de Continuidade de Negócios (PCN). Justificativa: Um plano de backup e recuperação robusto assegura a resiliência organizacional e minimiza o tempo de inatividade após eventos críticos.

5. Conclusões e Recomendações Finais A implementação das políticas descritas neste relatório elevará o nível de maturidade em segurança da informação da BrightTech Soluções Digitais Ltda., alinhando-a às práticas recomendadas por normas internacionais. Recomenda-se que a empresa estabeleça um processo contínuo de revisão dessas políticas, integrando-as ao ciclo de governança corporativa e de gestão de riscos. Além disso, sugere-se a criação de um Comitê de Segurança da Informação responsável por monitorar indicadores, promover treinamentos e garantir o cumprimento das diretrizes estabelecidas. A adoção dessas medidas não apenas fortalece a proteção de dados, mas também agrega valor à imagem institucional da BrightTech

perante clientes e parceiros.